

Software Requirements Specification (SRS)

CyberTrust KSA — AI-Powered Continuous Cybersecurity Compliance Platform

Document Version: 1.0

Date: June 8, 2026

Classification: Confidential

Prepared For: CyberTrust KSA Development Team

Standard: IEEE 830-1998 / ISO/IEC/IEEE 29148:2018

Table of Contents

- [1. Introduction](#)
 - [2. Overall Description](#)
 - [3. System Architecture](#)
 - [4. Functional Requirements](#)
 - [5. Non-Functional Requirements](#)
 - [6. External Interface Requirements](#)
 - [7. Data Requirements](#)
 - [8. Use Cases](#)
 - [9. System Constraints](#)
 - [10. Appendices](#)
-

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) document provides a complete and detailed description of the requirements for the **CyberTrust KSA** platform — an AI-powered continuous cybersecurity compliance management system designed specifically for the Kingdom of Saudi Arabia. This document serves as the authoritative reference for the development team,

stakeholders, quality assurance, and project management throughout the software development lifecycle.

1.2 Scope

CyberTrust KSA is a web-based platform that automates cybersecurity compliance assessments for Saudi enterprises seeking certification under three major frameworks:

- **NCA ECC** (National Cybersecurity Authority — Essential Cybersecurity Controls)
- **Saudi Aramco SACS-002** (Third-Party Cybersecurity Standard)
- **SABIC CyberTrust** (Cybersecurity Trust Standard for Suppliers)

The platform leverages artificial intelligence (OpenAI LLM) and Optical Character Recognition (OCR) to analyze, classify, and audit compliance records, reducing assessment time by 75% and costs by 60%.

1.3 Definitions, Acronyms, and Abbreviations

Term	Definition
NCA	National Cybersecurity Authority (الهيئة الوطنية للأمن السيبراني)
ECC	Essential Cybersecurity Controls
SACS-002	Saudi Aramco Cybersecurity Standard for Third Parties
SABIC	Saudi Basic Industries Corporation
OCR	Optical Character Recognition
LLM	Large Language Model
AI	Artificial Intelligence
SRS	Software Requirements Specification
RBAC	Role-Based Access Control
API	Application Programming Interface
MFA	Multi-Factor Authentication
SOC	Security Operations Center
SIEM	Security Information and Event Management
GRC	Governance, Risk, and Compliance
MVP	Minimum Viable Product
CR	Commercial Registration (السجل التجاري)
KPI	Key Performance Indicator

1.4 References

Document	Description
CyberTrust_KSA_Developer_Prototype_v3.2.pdf	System prototype and scenario definition
CyberTrust_KSA_Functional_Requirements.pdf	Functional requirements specification
CyberTrust_KSA_Technical_Requirements.pdf	Technical requirements specification
114NCA.pdf	NCA Essential Cybersecurity Controls document
SACS-002 Standard	Saudi Aramco Third-Party Cybersecurity Standard
SABIC CyberTrust Standard v1.0	SABIC Cybersecurity Trust Standard
CyberTrust_KSA_Classification_Framework_Combined.pdf	Classification framework

1.5 Overview

This document is organized according to IEEE 830 standard with adaptations for the specific needs of the CyberTrust KSA platform. Section 2 provides an overall system description. Section 3 details the system architecture. Section 4 specifies all functional requirements. Section 5 covers non-functional requirements. Sections 6-10 address interfaces, data, use cases, constraints, and appendices.

2. Overall Description

2.1 Product Perspective

CyberTrust KSA is a standalone web application that operates within the Saudi Arabian cybersecurity compliance ecosystem. It interfaces with:

- **OpenAI API** — for intelligent analysis, classification, and natural language processing

- **OCR Engine (Tesseract)** — for extracting text from uploaded documents and images
- **Email Services** — for notifications and alerts
- **Cloud Storage** — for secure document management

The platform does NOT integrate with:

- Nafath (National Digital Identity)
- Wathiq (Commercial Registration API)
- Any external government verification APIs

2.2 Product Functions

The platform provides the following high-level functions:

1. **Company Registration & Onboarding** — Standalone registration without external verification
2. **AI-Powered Classification** — Automatic determination of applicable compliance frameworks
3. **Compliance Controls Management** — 334 controls across NCA, Aramco, and SABIC
4. **Evidence Upload & AI Analysis** — OCR extraction and LLM-based compliance verification
5. **Gap Analysis & Risk Scoring** — Predictive risk assessment with remediation priorities
6. **Role-Specific Dashboards** — Tailored views for executives, compliance officers, IT teams, and business units
7. **Auditor Portal** — Dedicated interface for certified auditors
8. **Continuous Monitoring** — Real-time compliance tracking and alerting
9. **Bilingual Output** — All AI verdicts and reports in Arabic and English

2.3 User Classes and Characteristics

User Class	Description	Technical Level	Access Level
Company Admin	Registers company, manages users	Medium	Full company access
Compliance Officer	Manages compliance activities, uploads evidence	High	Compliance module
Executive	Views dashboards, approves reports	Low	Read-only dashboards
IT/Security Team	Manages technical controls, reviews vulnerabilities	High	Technical controls
Business Unit Manager	Monitors department compliance	Medium	Department-level
Certified Auditor	Reviews evidence, issues verdicts	High	Auditor portal
Platform Administrator	Manages platform, users, frameworks	High	Full system access

2.4 Operating Environment

Component	Specification
Backend Framework	Python Django 5.x
Database	PostgreSQL 15+ (production) / SQLite (development)
AI Engine	OpenAI GPT-4o API
OCR Engine	Tesseract OCR + pdf2image
Frontend	Django Templates + Tailwind CSS + Alpine.js
Web Server	Nginx + Gunicorn (production)
Operating System	Ubuntu 22.04 LTS
Cloud Provider	STC Cloud / Oracle Cloud KSA (recommended)
Minimum RAM	4 GB
Minimum Storage	100 GB

2.5 Design and Implementation Constraints

1.

Data Sovereignty: All data must be stored within the Kingdom of Saudi Arabia
2.

Language Support: Interface and AI outputs must support Arabic (RTL) and English
3.

No External Identity Verification: Registration is standalone (no Nafath/Wathiq)
4.

OpenAI Dependency: AI engine requires active OpenAI API subscription
5.

Compliance with NCA Standards: The platform itself must comply with NCA ECC
6.

Scalability: Must support 500+ concurrent companies
7.

Availability: 99.5% uptime SLA target

2.6 Assumptions and Dependencies

Assumptions:

- Companies will self-report accurate registration information
- Uploaded documents are legitimate compliance evidence
- Internet connectivity is available for OpenAI API calls

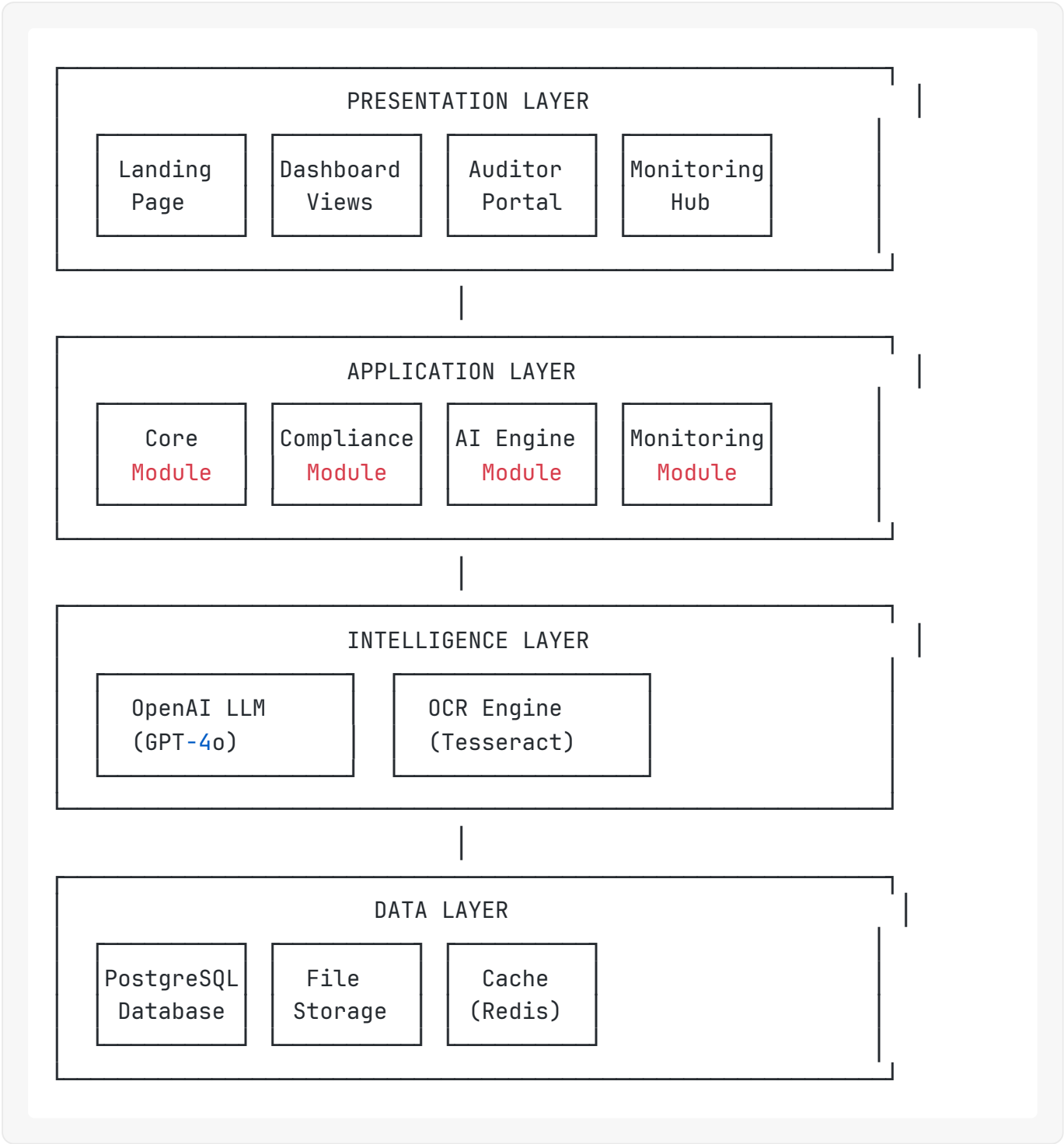
- Users have modern web browsers (Chrome, Firefox, Safari, Edge)

Dependencies:

- OpenAI API availability and pricing stability
 - Tesseract OCR accuracy for Arabic documents
 - Cloud infrastructure availability within KSA
-

3. System Architecture

3.1 High-Level Architecture



3.2 Module Decomposition

Module	Responsibility	Django App
Core	User management, authentication, company registration	core
Compliance	Controls database, evidence management, assessments	compliance
AI Engine	OpenAI integration, OCR, classification, analysis	ai_engine
Dashboard	Role-specific views, reports, visualizations	dashboard
Auditor Portal	Auditor workflows, review, certification	auditor_portal
Monitoring	Continuous compliance tracking, alerts	monitoring

3.3 Technology Stack

Layer	Technology	Justification
Backend	Python Django 5.x	Rapid development, security features, ORM
API	Django REST Framework	RESTful API for frontend/mobile
AI/ML	OpenAI GPT-4o	Best-in-class NLP for compliance analysis
OCR	Tesseract + pdf2image	Open-source, Arabic support
Frontend	Django Templates + Tailwind CSS	Server-rendered, fast, responsive
Database	PostgreSQL 15	ACID compliance, JSON support, scalability
Cache	Redis	Session management, task queuing
Task Queue	Celery	Async AI processing, scheduled tasks
File Storage	S3-compatible (local/cloud)	Scalable document storage
Deployment	Docker + Nginx + Gunicorn	Production-ready containerization

4. Functional Requirements

4.1 FR-001: Landing Page

Attribute	Value
ID	FR-001
Priority	High
Module	Core

Description: The system shall display a public landing page that presents the platform overview, the 5-step compliance process, ROI metrics, and supported framework badges.

Requirements:

- FR-001.1: Display platform name “CyberTrust KSA” with logo
- FR-001.2: Show the 5-step process (Register → AI Classify → Upload Evidence → Gap Analysis → Certify)
- FR-001.3: Display ROI metrics (75% faster assessments, 60% cost reduction, 334 controls mapped, ²⁴/₇ monitoring)
- FR-001.4: Show NCA, Aramco, and SABIC framework badges with control counts
- FR-001.5: Include “Register” and “Login” call-to-action buttons
- FR-001.6: Design must use government style (deep green #1a4731, white, neutral grays)
- FR-001.7: Page must be responsive (mobile, tablet, desktop)
- FR-001.8: Support Arabic and English language toggle

4.2 FR-002: Company Registration

Attribute	Value
ID	FR-002
Priority	Critical
Module	Core

Description: The system shall provide a standalone company registration form that collects essential company information without external API verification.

Requirements:

- FR-002.1: Collect company name (Arabic and English)
- FR-002.2: Collect Commercial Registration (CR) number
- FR-002.3: Collect company sector from predefined list:
 - Oil & Gas
 - Petrochemicals
 - Banking & Finance

- Healthcare
 - Telecommunications
 - Government
 - Education
 - Retail
 - Manufacturing
 - Technology
 - Construction
 - Transportation
 - Energy & Utilities
 - Other
 - FR-002.4: Collect company size:
 - Micro (1-9 employees)
 - Small (10-49 employees)
 - Medium (50-249 employees)
 - Large (250-999 employees)
 - Enterprise (1000+ employees)
 - FR-002.5: Collect vendor/certification targets (multi-select):
 - Saudi Aramco (SACS-002)
 - SABIC (CyberTrust)
 - Government (NCA ECC)
 - FR-002.6: Collect primary contact information (name, email, phone, role)
 - FR-002.7: Create user account with email and password
 - FR-002.8: Send email verification upon registration
 - FR-002.9: No external API calls for verification (standalone)
 - FR-002.10: Validate CR number format (10 digits)
 - FR-002.11: Prevent duplicate CR number registration
-

4.3 FR-003: AI-Powered Classification Engine

Attribute	Value
ID	FR-003
Priority	Critical
Module	AI Engine

Description: After registration, the system shall use OpenAI to analyze the company profile and automatically determine the applicable compliance control sets.

Requirements:

- FR-003.1: Trigger classification automatically after company registration
- FR-003.2: Send company profile (sector, size, vendor targets) to OpenAI for analysis
- FR-003.3: Determine applicable frameworks based on vendor targets:
 - Aramco target → SACS-002 controls
 - SABIC target → SABIC CyberTrust controls
 - Government target → NCA ECC controls
- FR-003.4: Determine risk tier based on sector and size:
 - Tier 1 (Critical): Oil & Gas, Government, Banking — Large/Enterprise
 - Tier 2 (High): Healthcare, Telecom, Energy — Medium+
 - Tier 3 (Standard): All other combinations
- FR-003.5: Generate a classification report with:
 - Assigned risk tier
 - Applicable frameworks
 - Total number of controls to address
 - Estimated timeline for compliance
 - Priority domains to address first
- FR-003.6: Output classification in both Arabic and English
- FR-003.7: Allow manual override of AI classification by platform admin
- FR-003.8: Store classification history for audit trail
- FR-003.9: Re-classify when company profile changes

4.4 FR-004: Compliance Controls Database

Attribute	Value
ID	FR-004
Priority	Critical
Module	Compliance

Description: The system shall maintain a comprehensive database of 334 compliance controls mapped across NCA ECC, Aramco SACS-002, and SABIC CyberTrust.

Requirements:

- FR-004.1: Store controls with the following attributes:
 - Control ID (unique identifier per framework)
 - Title (English)
 - Title (Arabic)
 - Description (English)
 - Description (Arabic)
 - Framework (NCA/Aramco/SABIC)
 - Domain (e.g., Governance, Access Control, Network Security)
 - Priority (Critical/High/Medium/Low)
 - Evidence type required (Policy/Screenshot/Report/Interview)
 - Evidence guidance (English)
 - Evidence guidance (Arabic)
 - Applicable sectors
 - Applicable company sizes
 - Mandatory flag
- FR-004.2: Organize controls by domain:
 - Cybersecurity Governance
 - Cybersecurity Defense
 - Cybersecurity Resilience
 - Third-Party Cybersecurity

- Industrial Control Systems Security
 - Identity & Access Management
 - Network Security
 - Data Protection
 - Application Security
 - Cloud Security
 - Physical Security
 - Human Resources Security
 - Cryptography
 - Security Operations
 - Vulnerability Management
 - Business Continuity
 - Compliance & Audit
- FR-004.3: Implement cross-mapping between frameworks (one control may satisfy multiple frameworks)
 - FR-004.4: Filter controls by framework, domain, priority, and applicability
 - FR-004.5: Display control compliance status per company (Compliant/Non-Compliant/Partial/Not Assessed)
 - FR-004.6: Calculate compliance percentage per framework and per domain
 - FR-004.7: Support bulk import/export of controls (Excel format)
 - FR-004.8: Version control for control updates

4.5 FR-005: Evidence Upload & OCR Processing

Attribute	Value
ID	FR-005
Priority	Critical
Module	Compliance + AI Engine

Description: The system shall allow users to upload evidence documents for each control, extract text using OCR, and prepare content for AI analysis.

Requirements:

- FR-005.1: Support file upload for the following formats:
 - PDF documents
 - Images (PNG, JPG, JPEG, TIFF)
 - Microsoft Word (DOCX)
 - Microsoft Excel (XLSX)
 - Plain text (TXT)
 - FR-005.2: Maximum file size: 50 MB per file
 - FR-005.3: Extract text from uploaded PDFs using pdf2image + Tesseract OCR
 - FR-005.4: Extract text from uploaded images using Tesseract OCR
 - FR-005.5: Support Arabic text extraction (Arabic OCR model)
 - FR-005.6: Support English text extraction
 - FR-005.7: Store extracted text alongside original file
 - FR-005.8: Allow multiple evidence files per control
 - FR-005.9: Track upload date, uploader, and file metadata
 - FR-005.10: Provide upload progress indicator
 - FR-005.11: Validate file type and size before upload
 - FR-005.12: Generate thumbnail previews for uploaded documents
 - FR-005.13: Allow evidence deletion with audit trail
-

4.6 FR-006: AI-Powered Evidence Analysis

Attribute	Value
ID	FR-006
Priority	Critical
Module	AI Engine

Description: The system shall use OpenAI to analyze extracted evidence text against the specific control requirements and produce a compliance verdict.

Requirements:

- FR-006.1: Send extracted text + control requirements to OpenAI for analysis
 - FR-006.2: AI shall evaluate evidence against the following criteria:
 - Relevance to the specific control
 - Completeness of coverage
 - Currency (is the document up-to-date?)
 - Specificity (does it address the exact requirement?)
 - Implementation evidence (not just policy, but proof of execution)
 - FR-006.3: Generate a structured verdict:
 - Status: Compliant / Non-Compliant / Partially Compliant / Insufficient Evidence
 - Confidence Score: 0-100%
 - Detailed Reasoning (English)
 - Detailed Reasoning (Arabic)
 - Recommendations for improvement (English)
 - Recommendations for improvement (Arabic)
 - Missing elements identified
 - FR-006.4: Flag evidence that appears fabricated or templated without customization
 - FR-006.5: Compare evidence against industry best practices
 - FR-006.6: Provide specific actionable recommendations for non-compliant items
 - FR-006.7: Store all AI analysis results with timestamps
 - FR-006.8: Allow re-analysis when new evidence is uploaded
 - FR-006.9: Support batch analysis of multiple controls
 - FR-006.10: Handle API failures gracefully with retry logic
 - FR-006.11: Rate limit API calls to manage costs
-

4.7 FR-007: Gap Analysis & Predictive Risk Module

Attribute	Value
ID	FR-007
Priority	High
Module	AI Engine

Description: The system shall calculate compliance scores per framework, identify gaps, and predict risk levels with remediation priorities.

Requirements:

- FR-007.1: Calculate overall compliance score per framework (NCA/Aramco/SABIC)
 - FR-007.2: Calculate compliance score per domain
 - FR-007.3: Identify all non-compliant and partially compliant controls
 - FR-007.4: Prioritize gaps by:
 - Control criticality (Critical > High > Medium > Low)
 - Framework weight (mandatory controls first)
 - Remediation effort (quick wins first)
 - Audit probability (likelihood of auditor checking)
 - FR-007.5: Generate risk score (0-100) per framework
 - FR-007.6: Predict probability of audit failure per domain
 - FR-007.7: Estimate time-to-compliance based on gap count and complexity
 - FR-007.8: Generate remediation roadmap with timeline
 - FR-007.9: Provide AI-generated remediation suggestions for each gap
 - FR-007.10: Track gap closure progress over time
 - FR-007.11: Generate executive summary of gaps (bilingual)
 - FR-007.12: Export gap analysis report (PDF format)
-

4.8 FR-008: Role-Specific Dashboards

Attribute	Value
ID	FR-008
Priority	High
Module	Dashboard

Description: The system shall provide tailored dashboard views for each user role.

FR-008.1: Executive Dashboard

- Overall compliance score (gauge chart)
- Risk heatmap by domain
- ROI metrics (time saved, cost reduction)
- Trend charts (compliance progress over time)
- Board-ready report generation
- Certificate status and renewal dates
- Comparison with industry benchmarks

FR-008.2: Compliance Officer Dashboard

- Full control checklist with status indicators
- Evidence upload queue
- AI analysis results summary
- Audit readiness percentage
- Upcoming deadlines and milestones
- Document management interface
- Framework-specific views

FR-008.3: IT/Security Team Dashboard

- Technical controls status
- Vulnerability queue with priorities

- Automated testing status
- Network security compliance
- Endpoint security compliance
- Patch management status
- Configuration drift alerts

FR-008.4: Business Unit Manager Dashboard

- Department-level compliance status
- Training completion rates
- Policy acknowledgment status
- Incident reports relevant to department
- Action items assigned to department

4.9 FR-009: Auditor Portal

Attribute	Value
ID	FR-009
Priority	High
Module	Auditor Portal

Description: The system shall provide a dedicated portal for certified auditors to review AI-analyzed evidence and issue compliance verdicts.

Requirements:

- FR-009.1: Separate login for certified auditors
- FR-009.2: View assigned companies and their compliance status
- FR-009.3: Review AI analysis results for each control
- FR-009.4: View original uploaded evidence documents
- FR-009.5: Add auditor notes and observations per control
- FR-009.6: Override AI verdict with auditor judgment
- FR-009.7: Request additional evidence from company

- FR-009.8: Mark controls as verified/rejected
- FR-009.9: Generate final compliance report
- FR-009.10: Digital signature on audit reports
- FR-009.11: Track audit progress and time spent
- FR-009.12: Communication channel with company compliance team
- FR-009.13: Export audit findings (PDF)

4.10 FR-010: Continuous Compliance Monitoring

Attribute	Value
ID	FR-010
Priority	High
Module	Monitoring

Description: The system shall continuously monitor compliance status and alert stakeholders of changes.

Requirements:

- FR-010.1: Daily compliance score recalculation
- FR-010.2: Monthly auto-generated compliance reports
- FR-010.3: Certificate renewal countdown timer
- FR-010.4: Real-time alerts for:
 - Compliance score drop below threshold
 - Evidence document expiration
 - Policy document updates needed
 - Configuration drift detected
 - New controls added to frameworks
- FR-010.5: Email notifications for critical alerts
- FR-010.6: Dashboard notification center
- FR-010.7: Compliance trend analysis (weekly/monthly/quarterly)
- FR-010.8: Automated reminder for upcoming audits

- FR-010.9: Integration readiness for SIEM/log feeds (future)
- FR-010.10: Scheduled compliance health checks

4.11 FR-011: Reporting & Export

Attribute	Value
ID	FR-011
Priority	Medium
Module	Dashboard

Description: The system shall generate various reports for different stakeholders.

Requirements:

- FR-011.1: Executive summary report (PDF)
- FR-011.2: Detailed compliance report per framework (PDF)
- FR-011.3: Gap analysis report with remediation plan (PDF)
- FR-011.4: Audit-ready report package
- FR-011.5: Board presentation export
- FR-011.6: All reports in bilingual format (Arabic/English)
- FR-011.7: Custom date range for reports
- FR-011.8: Scheduled report generation and email delivery
- FR-011.9: Export data to Excel format
- FR-011.10: Report templates customization

4.12 FR-012: User & Access Management

Attribute	Value
ID	FR-012
Priority	High
Module	Core

Description: The system shall manage user accounts, roles, and permissions.

Requirements:

- FR-012.1: User registration with email verification
 - FR-012.2: Role-Based Access Control (RBAC):
 - Platform Admin
 - Company Admin
 - Compliance Officer
 - Executive (read-only)
 - IT/Security Team
 - Business Unit Manager
 - Auditor
 - FR-012.3: Multi-Factor Authentication (MFA) support
 - FR-012.4: Password policy enforcement (minimum 12 characters, complexity rules)
 - FR-012.5: Session management with configurable timeout
 - FR-012.6: Account lockout after failed attempts
 - FR-012.7: Password reset via email
 - FR-012.8: User activity audit log
 - FR-012.9: Invite users to company account
 - FR-012.10: Deactivate/reactivate user accounts
-

5. Non-Functional Requirements

5.1 Performance Requirements

ID	Requirement	Target
NFR-001	Page load time	< 3 seconds
NFR-002	API response time	< 2 seconds (excluding AI calls)
NFR-003	AI analysis response	< 30 seconds per control
NFR-004	OCR processing time	< 10 seconds per page
NFR-005	Concurrent users	500+ simultaneous
NFR-006	File upload speed	Support up to 50 MB
NFR-007	Dashboard refresh	< 5 seconds
NFR-008	Report generation	< 60 seconds
NFR-009	Database query time	< 500ms for standard queries
NFR-010	Search response	< 2 seconds

5.2 Security Requirements

ID	Requirement	Description
NFR-011	Data encryption at rest	AES-256 for stored data
NFR-012	Data encryption in transit	TLS 1.3 for all communications
NFR-013	Authentication	JWT tokens with secure session management
NFR-014	Authorization	RBAC with principle of least privilege
NFR-015	Input validation	Server-side validation for all inputs
NFR-016	SQL injection prevention	Parameterized queries via Django ORM
NFR-017	XSS prevention	Content Security Policy + output encoding
NFR-018	CSRF protection	Django CSRF middleware enabled
NFR-019	File upload security	Type validation, virus scanning, size limits
NFR-020	API rate limiting	100 requests/minute per user
NFR-021	Audit logging	All user actions logged with timestamps
NFR-022	Data backup	Daily automated backups with 30-day retention
NFR-023	Penetration testing	Annual third-party penetration test
NFR-024	Vulnerability scanning	Monthly automated vulnerability scans

5.3 Availability & Reliability

ID	Requirement	Target
NFR-025	System availability	99.5% uptime
NFR-026	Planned maintenance window	< 4 hours/month
NFR-027	Recovery Time Objective (RTO)	< 4 hours
NFR-028	Recovery Point Objective (RPO)	< 1 hour
NFR-029	Failover mechanism	Automatic database failover
NFR-030	Error handling	Graceful degradation on AI service failure

5.4 Scalability Requirements

ID	Requirement	Target
NFR-031	Horizontal scaling	Support load balancer distribution
NFR-032	Database scaling	Read replicas for reporting
NFR-033	Storage scaling	Unlimited document storage (cloud)
NFR-034	User scaling	Support 10,000+ registered companies
NFR-035	Control scaling	Support 1,000+ controls per framework

5.5 Usability Requirements

ID	Requirement	Description
NFR-036	Language support	Full Arabic (RTL) and English support
NFR-037	Responsive design	Mobile, tablet, and desktop support
NFR-038	Accessibility	WCAG 2.1 Level AA compliance
NFR-039	Browser support	Chrome, Firefox, Safari, Edge (latest 2 versions)
NFR-040	Onboarding	Guided tour for new users
NFR-041	Help documentation	Context-sensitive help and user manual
NFR-042	Error messages	Clear, actionable error messages (bilingual)

5.6 Compliance Requirements

ID	Requirement	Description
NFR-043	Data sovereignty	All data stored within KSA borders
NFR-044	NCA compliance	Platform itself complies with NCA ECC
NFR-045	PDPL compliance	Saudi Personal Data Protection Law compliance
NFR-046	Audit trail	Complete audit trail for all system actions
NFR-047	Data retention	Configurable retention policies per data type
NFR-048	Right to deletion	Support data deletion requests

6. External Interface Requirements

6.1 User Interfaces

Interface	Description	Users
Landing Page	Public marketing page	All visitors
Registration Form	Company onboarding	New companies
Login Page	Authentication	All registered users
Executive Dashboard	High-level metrics	Executives
Compliance Dashboard	Detailed compliance view	Compliance Officers
IT Dashboard	Technical controls view	IT/Security Teams
BU Dashboard	Department view	Business Unit Managers
Auditor Portal	Evidence review	Certified Auditors
Admin Panel	Platform management	Platform Admins
Monitoring Hub	Continuous compliance	All company users

6.2 Hardware Interfaces

No specific hardware interfaces required. The system is entirely web-based.

6.3 Software Interfaces

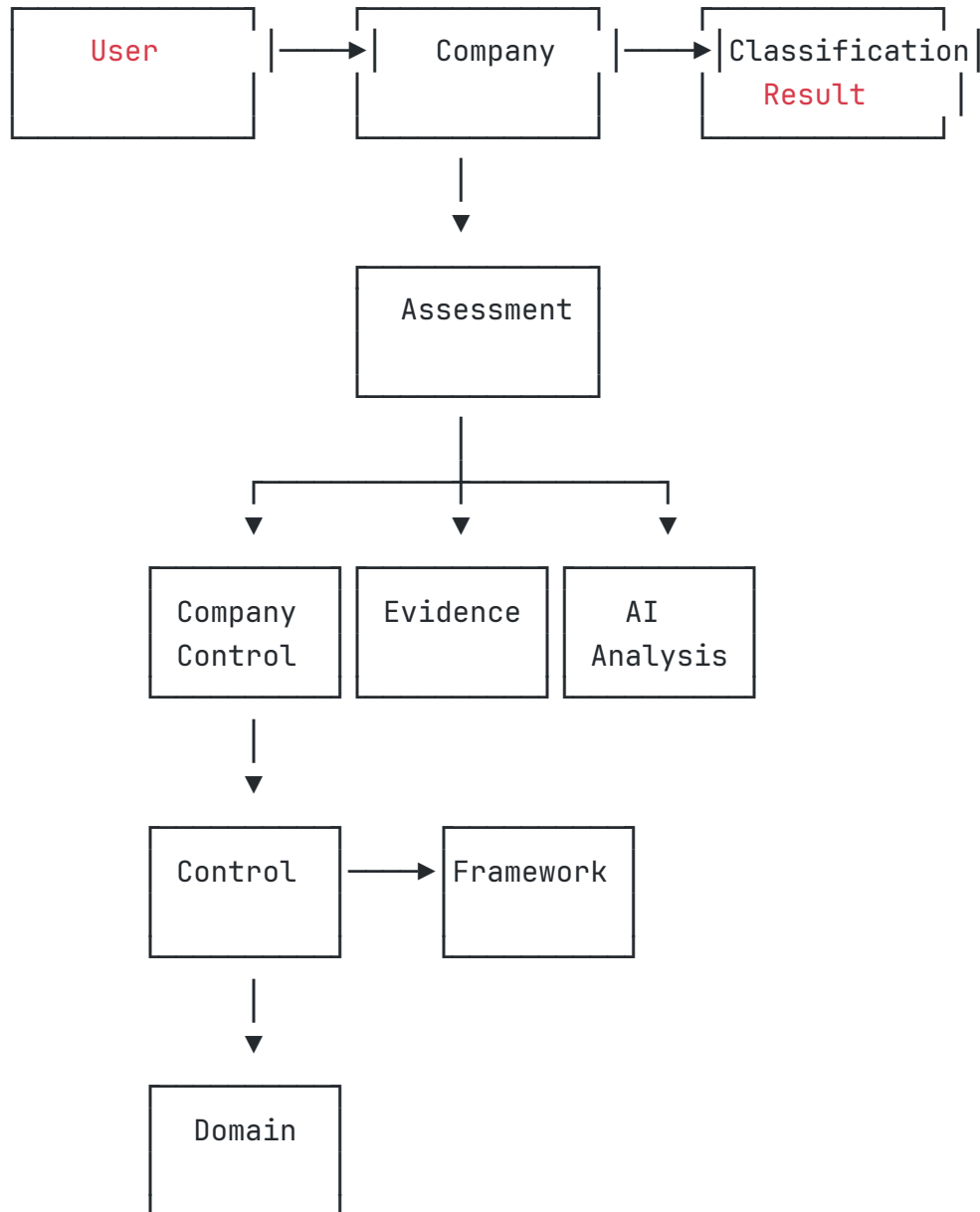
Interface	Protocol	Purpose
OpenAI API	HTTPS/REST	AI analysis and classification
SMTP Server	SMTP/TLS	Email notifications
S3-Compatible Storage	HTTPS	Document storage
Redis	TCP	Caching and task queuing
PostgreSQL	TCP	Primary database

6.4 Communication Interfaces

Interface	Protocol	Description
Web Browser	HTTPS	Primary user interface
REST API	HTTPS/JSON	Programmatic access
WebSocket	WSS	Real-time notifications (future)
Email	SMTP/TLS	Notifications and reports

7. Data Requirements

7.1 Data Model (Core Entities)



7.2 Database Tables

Table	Description	Estimated Rows
users	User accounts	50,000+
companies	Registered companies	10,000+
frameworks	Compliance frameworks (3)	3
domains	Control domains	50+
controls	Compliance controls	334+
control_mappings	Cross-framework mappings	500+
company_controls	Company-specific control status	3,000,000+
evidence	Uploaded evidence files	1,000,000+
ai_analyses	AI analysis results	1,000,000+
assessments	Compliance assessments	100,000+
classification_results	AI classification outputs	10,000+
audit_reports	Auditor reports	50,000+
alerts	Monitoring alerts	500,000+
compliance_scores	Historical score records	5,000,000+
audit_logs	System audit trail	10,000,000+

7.3 Data Retention

Data Type	Retention Period	Justification
User accounts	Account lifetime + 2 years	Legal requirement
Company data	Active + 5 years	Audit trail
Evidence files	7 years	Regulatory requirement
AI analysis results	5 years	Audit trail
Audit reports	10 years	Legal compliance
System logs	1 year	Security monitoring
Compliance scores	Indefinite	Historical trending

8. Use Cases

8.1 UC-001: Company Registration and Classification

Actor: Company Admin

Precondition: None

Trigger: User clicks “Register” on landing page

Main Flow:

1. User fills registration form (company name, CR, sector, size, targets)
2. System validates input data
3. System creates company account and user account
4. System sends email verification
5. User verifies email
6. System triggers AI classification engine
7. AI analyzes company profile and determines applicable frameworks
8. System displays classification result with applicable controls
9. System creates company-specific control checklist

Alternative Flows:

- 2a. Invalid data → Display error messages
- 6a. OpenAI unavailable → Queue classification for retry, show pending status

Postcondition: Company registered with applicable framework controls assigned

8.2 UC-002: Evidence Upload and AI Analysis

Actor: Compliance Officer

Precondition: Company registered and classified

Trigger: User navigates to a specific control

Main Flow:

1. User selects a control from the compliance checklist
2. System displays control details and evidence requirements
3. User uploads evidence document (PDF/Image/DOCX)
4. System validates file type and size
5. System extracts text using OCR (Tesseract)
6. System sends extracted text + control requirements to OpenAI
7. AI analyzes evidence and generates verdict
8. System displays verdict (status, confidence, reasoning, recommendations)
9. System updates control compliance status
10. System recalculates framework compliance score

Alternative Flows:

- 4a. Invalid file → Display error, request re-upload
- 5a. OCR fails → Notify user, allow manual text input
- 6a. OpenAI unavailable → Queue analysis, show pending status
- 7a. Low confidence → Flag for human review

Postcondition: Control status updated with AI verdict

8.3 UC-003: Gap Analysis Generation

Actor: Compliance Officer / Executive

Precondition: At least 50% of controls assessed

Trigger: User requests gap analysis

Main Flow:

1. User navigates to Gap Analysis section
2. System calculates compliance scores per framework
3. System identifies all non-compliant and partially compliant controls
4. AI prioritizes gaps by criticality and remediation effort
5. System generates risk score per framework
6. AI predicts audit failure probability per domain
7. System displays gap analysis dashboard with visualizations
8. System generates remediation roadmap
9. User can export report as PDF

Postcondition: Gap analysis report generated and available

8.4 UC-004: Auditor Review

Actor: Certified Auditor

Precondition: Company has completed self-assessment

Trigger: Auditor assigned to company

Main Flow:

1. Auditor logs into auditor portal
2. System displays assigned companies
3. Auditor selects a company to review
4. System displays AI-analyzed controls with verdicts
5. Auditor reviews each control's evidence and AI analysis
6. Auditor adds notes and observations
7. Auditor confirms or overrides AI verdict
8. Auditor requests additional evidence if needed
9. Company uploads additional evidence
10. Auditor completes review and generates final report
11. System issues compliance certificate (if passed)

Alternative Flows:

- 8a. Company fails to provide evidence → Auditor marks as non-compliant
- 10a. Company fails audit → System generates remediation plan

Postcondition: Audit completed, certificate issued or remediation plan generated

8.5 UC-005: Continuous Monitoring Alert

Actor: System (automated)

Precondition: Company has active compliance assessment

Trigger: Scheduled daily check or event-driven trigger

Main Flow:

1. System performs daily compliance score recalculation
2. System checks for expired evidence documents
3. System checks for policy update requirements
4. System detects compliance score drop below threshold
5. System generates alert with details
6. System sends email notification to relevant stakeholders
7. System updates dashboard notification center
8. Compliance Officer reviews alert and takes action

Alternative Flows:

- 4a. No issues detected → Log healthy status, no alert
- 6a. Email delivery fails → Retry with exponential backoff

Postcondition: Stakeholders notified of compliance changes

9. System Constraints

9.1 Technical Constraints

Constraint	Description	Impact
OpenAI API dependency	System requires active OpenAI subscription	AI features unavailable if API is down
OCR accuracy	Tesseract may have reduced accuracy for handwritten Arabic	May require manual correction
File size limit	50 MB per upload	Large documents may need splitting
API rate limits	OpenAI has rate limits per tier	Batch processing may be throttled
Database size	PostgreSQL performance degrades at very large scales	May need sharding at 10M+ rows

9.2 Business Constraints

Constraint	Description
No external verification	Registration must work without Nafath/Wathiq
Data sovereignty	All data must remain within KSA
Bilingual requirement	All outputs must be in Arabic and English
Framework updates	System must accommodate annual framework revisions
Auditor independence	Platform must not influence auditor judgment

9.3 Regulatory Constraints

Constraint	Regulation	Requirement
Data protection	Saudi PDPL	Consent, minimization, right to deletion
Cybersecurity	NCA regulations	Platform must self-comply with NCA ECC
Cloud hosting	CITC regulations	Cloud provider must be licensed in KSA
Audit standards	SOCPA	Audit reports must meet SOCPA standards

10. Appendices

10.1 Appendix A: Compliance Frameworks Summary

Framework	Controls	Target Audience	Issuing Body
NCA ECC	114+	Government entities, critical infrastructure	National Cybersecurity Authority
Aramco SACS-002	92+	Aramco vendors and suppliers	Saudi Aramco
SABIC CyberTrust	94+	SABIC suppliers and service providers	SABIC

10.2 Appendix B: AI Model Specifications

Parameter	Value
Model	GPT-4o (latest)
Max tokens (input)	128,000
Max tokens (output)	4,096
Temperature (classification)	0.1
Temperature (analysis)	0.3
Temperature (recommendations)	0.5
Response format	JSON (structured)
Languages	Arabic, English
Retry policy	3 attempts with exponential backoff
Timeout	60 seconds

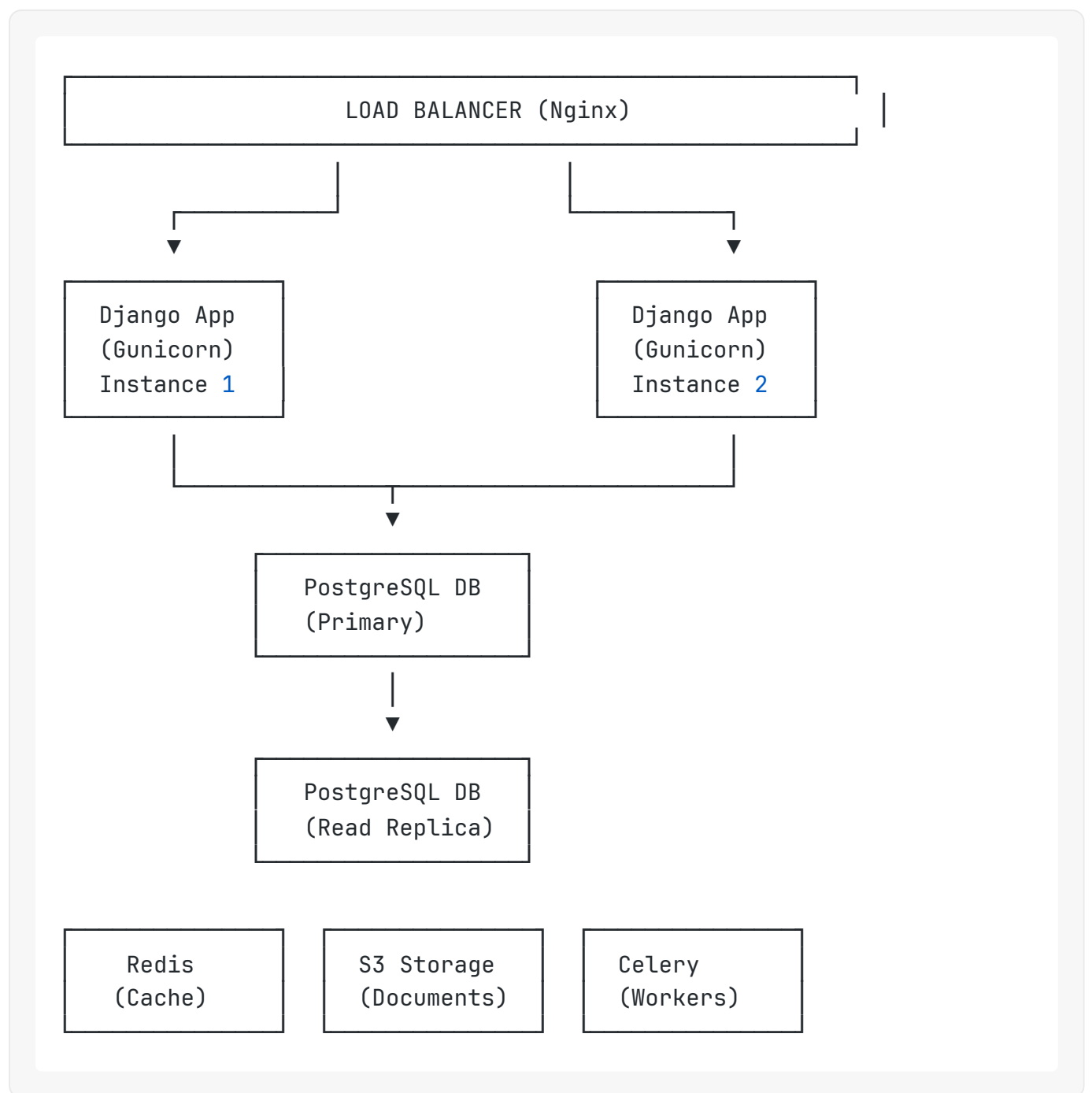
10.3 Appendix C: OCR Specifications

Parameter	Value
Engine	Tesseract 5.x
Languages	Arabic (ara) + English (eng)
Input formats	PDF, PNG, JPG, JPEG, TIFF
DPI for conversion	300
Preprocessing	Grayscale, deskew, noise removal
Output format	UTF-8 text
Confidence threshold	60% minimum

10.4 Appendix D: API Endpoints Summary

Endpoint	Method	Description	Auth
/api/v1/register/	POST	Company registration	Public
/api/v1/login/	POST	User authentication	Public
/api/v1/classify/	POST	Trigger AI classification	Protected
/api/v1/controls/	GET	List applicable controls	Protected
/api/v1/controls/{id}/	GET	Control details	Protected
/api/v1/evidence/upload/	POST	Upload evidence	Protected
/api/v1/evidence/{id}/analyze/	POST	Trigger AI analysis	Protected
/api/v1/gap-analysis/	GET	Generate gap analysis	Protected
/api/v1/dashboard/executive/	GET	Executive metrics	Protected
/api/v1/dashboard/compliance/	GET	Compliance metrics	Protected
/api/v1/monitoring/scores/	GET	Compliance scores	Protected
/api/v1/monitoring/alerts/	GET	Active alerts	Protected
/api/v1/reports/generate/	POST	Generate report	Protected
/api/v1/auditor/assignments/	GET	Auditor assignments	Auditor
/api/v1/auditor/review/{id}/	POST	Submit review	Auditor

10.5 Appendix E: Deployment Architecture



10.6 Appendix F: Project Timeline (Estimated)

Phase	Duration	Deliverables
Phase 1: Foundation	4 weeks	Django setup, models, auth, registration
Phase 2: AI Engine	6 weeks	OpenAI integration, OCR, classification
Phase 3: Compliance	4 weeks	Controls DB, evidence upload, analysis
Phase 4: Dashboards	4 weeks	All role-specific dashboards
Phase 5: Auditor Portal	3 weeks	Auditor workflows, reporting
Phase 6: Monitoring	3 weeks	Continuous monitoring, alerts
Phase 7: Testing	4 weeks	QA, security testing, UAT
Phase 8: Deployment	2 weeks	Production deployment, go-live
Total	30 weeks	Full platform

Document Approval

Role	Name	Signature	Date
Project Owner	_____	_____	_____
Technical Lead	_____	_____	_____
QA Lead	_____	_____	_____
Security Officer	_____	_____	_____

End of Document